



HACKTHEBOX

LockPick 2.0 Write-up



1st December 2023

Prepared by: blitztide

Machine Author(s): sebh24

Difficulty: **Hard**

Scenario

We've been hit by Ransomware again, but this time the threat actor seems to have upped their skillset. Once again a they've managed to encrypt a large set of our files. It is our policy NOT to negotiate with criminals. Please recover the files they have encrypted - we have no other option! Unfortunately our CEO is on a no-tech retreat so can't be reached. Warning This is a warning that this Sherlock includes software that is going to interact with your computer and files. This software has been intentionally included for educational purposes and is NOT intended to be executed or used otherwise. Always handle such files in isolated, controlled, and secure environments. One the Sherlock zip has been unzipped, you will find a DANGER.txt file. Please read this to proceed.

Warning

This is a warning that this Sherlock includes software that is going to interact with your computer and files. This software has been intentionally included for educational purposes and is NOT intended to be executed or used otherwise. Always handle such files in isolated, controlled, and secure environments.

Once the Sherlock zip has been unzipped, you will find a DANGER.txt file. Please read this to proceed.

The analysis in this Sherlock has been performed in an isolated (from work/personal devices) network with a live internet connection.

Artefacts Provided

- lockpick2.zip - 4a9765cfc4c7faec1f64bd07daa76a08e6c8742d3fcec1cb976b4e42a04357d8

Initial Analysis

Opening the downloadable zip file we have the following files:

```
> find . -exec file {} \;  
.: directory  
./share: directory  
./share/expanding-horizons.pdf.24bes: data  
./share/countdown.txt: ASCII text  
./share/takeover.docx.24bes: data  
./malware.zip: Zip archive data, at least v1.0 to extract, compression  
method=store  
./DANGER.txt: ASCII text
```

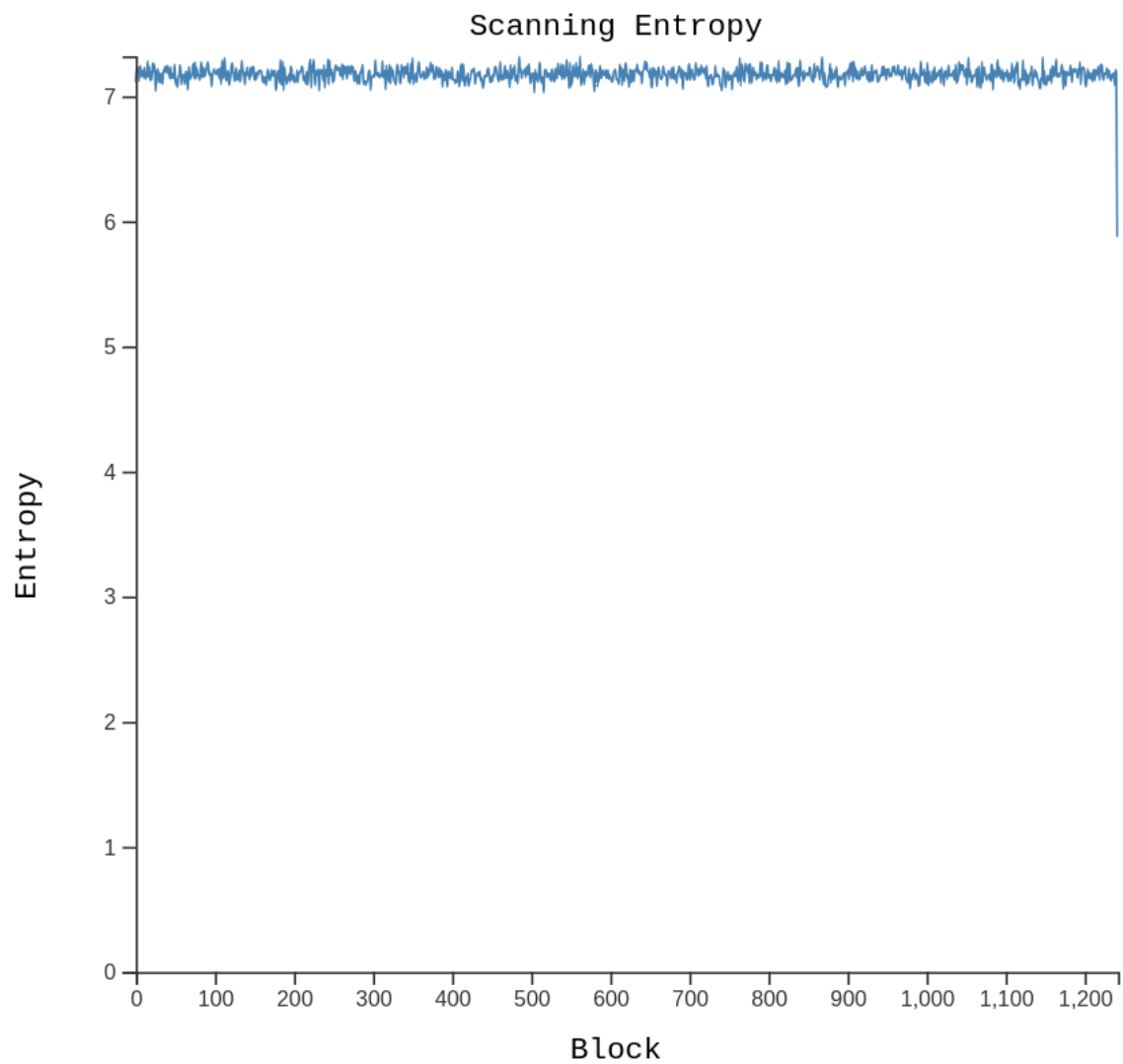
Files

Countdown.txt

This appears to be a ransomware note in the form of a poem, it allows us to identify the 'customer service' onion address and the bitcoin address (1BvBMSEYstWetqTFn5Au4m4GFg7xJaNVN2) to send the payment of £1,000,000.

*.24bes

Using the `Entropy` function in [CyberChef](#) we are able to see that there is a near constant Scanning entropy of above 7, this strongly indicates that it is compressed/encrypted as there are no discernible patterns.



malware.zip

Using the password contained within DANGER.txt we are able to open and extract the malware contained within.

The malware is a file called `update` and it is a statically linked ELF executable.

Malware Analysis

Doing a quick triage on [VirusTotal](https://www.virustotal.com/) we can see that it is detected as a Linux Trojan.

30
/ 63

30 security vendors and no sandboxes flagged this file as malicious

Reanalyze Similar More

3d3c2efab3c0e8db75276859df16c59ec196129cebddd4cc54862de91444336fa
update

elf 64bits upx shared-lib

Size 9.32 KB
Last Analysis Date 2 days ago

Community Score

DETECTION DETAILS COMMUNITY 1

Join the VT Community and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Popular threat label trojan.jqeqp/r002c0pkq23

Threat categories trojan

Family labels jqeqp r002c0pkq23

Security vendors' analysis Do you want to automate checks?

running strings on the executable we can find that it is a [UPX](#) packed executable due to the following output:

```

> strings update
USQRH
W^YH
PROT_EXEC|PROT_WRITE failed.
$Info: This file is packed with the UPX executable packer
http://upx.sf.net $
$Id: UPX 3.96 Copyright (C) 1996-2020 the UPX Team. All Rights Reserved.
$_j<X
RPI)
WQM)
j"AZR^j
Y^_]j
/proc/self/exe
IuDSWH
s2V^
XAVAWPH
YT_j
AY^_
D$ [E)

```

Strace

We run strace on the malware and it raises an error saying that it is unable to find `libcurl-4` which is a library to perform network operations such as web requests and FTP file transfers.

```
> strace -o update.strace.log ./update
./update: error while loading shared libraries: libcurl.so.4: cannot open
shared object file: No such file or directory

> apt install libcurl4
--- snip ---
> strace -o update.strace.log ./update

Running update, testing update endpoints
Updating https://rb.gy/ehc6..... Successful
Updating https://rb.gy/aw3t1..... Successful
Updating https://rb.gy/fziug..... Successful
Apdating https://rb.gy/irzmuU

ET..... Successful
Update complete - thank you for your patience.
> cat update.strace.log | grep
```

These URLs appear to be HTTPS, in order to see what is in them we need to MITM the connections as we are unable to see inside of an SSL socket due it being encrypted.

Network Analysis

Knowing that the library used is curl, there is a strong chance that it accepts `http_proxy` and `https_proxy` environment variables, which means I can use a standard proxy to intercept any web requests.

I can now start a [mitmweb](#) instance and detonate the malware with the above environment variables `http_proxy` and `https_proxy` set to point at the mitmproxy IP address and port.

FileStartOptionsFlow

ReplayDuplicateRevertDeleteMark

DownloadExport

ResumeAbort

Flow Modification

Export

Interception

Path	Method	Status	Size	Time	Request	Response	Connection	Timing
https://rb.gy/3flsy	GET	301		0 121ms	HTTP/1.1 200 OK			
https://www.dro...	GET	302	52b	214ms	Accept-Ranges: bytes Cache-Control: max-age=60 Content-Disposition: attachment; filename="updater"; filename*=UTF-8'updater Content-Security-Policy: sandbox Etag: 1683030600919683d Pragma: public Referrer-Policy: no-referrer Vary: Origin X-Content-Security-Policy: sandbox X-Content-Type-Options: nosniff X-Robots-Tag: noindex, nofollow, noimageindex X-Server-Response-Time: 188 X-Webkit-Csp: sandbox Content-Type: application/binary Accept-Encoding: identity, gzip Date: Fri, 01 Dec 2023 12:11:37 GMT Server: envoy Strict-Transport-Security: max-age=31536000; includeSubDomains; preload Content-Length: 48 X-Dropbox-Response-Origin: far_remote X-Dropbox-Request-Id: e6e0fe49cc5e4a88ac5c5cf7fb802021			
https://www.dro...	GET	302	320b	431ms				
https://ucca9e2d...	GET	200	48b	333ms				

Hexdump

EditReplaceView: auto

```

0000000000 f3 fc 05 6d a1 18 5e ae 37 0d 76 d4
0000000010 9f 4e fd 1c 15 85 cd e3 a7 bc c6 cb
0000000020 01 44 8c 79 09 93 9e 13 ce 35 97 10

```

no-http2*8080mitmproxy 10.1.5

This shows that there is only one URL that is actually checked `https://rb.gy/3flsy` which is a redirect to `https://www.dropbox.com/s/2hqqpmtc2mdwij4/updater?dl=1` which has two more redirects before it download the following binary in hex:

f3fc056da1185eae370d76d47c4cf9db9f4efd1c1585cde3a7bcc6cb5889f6db01448c7909939e13ce359710b9f0dc2e

this binary must be the encryption material, there's a total of 48 bytes returned which is 384 bits which is very small for an asymmetric cipher suite, so we will assume it is symmetric going forwards.

There are many cipher suites that we can choose a common one would be AES which can take 128/192/256 bit keys and require a 128 bit Initialisation vector, assuming the hex above is correct we can guess it is a 256bit key with an 128 bit IV, which gives us a total of 48 bytes.

Loading the file `expanding-horizons.pdf.24bes` into cyberchef we can attempt an AES decryption using the first 32 bytes as the key and the last 16 bytes as the IV.

The default settings allowed us to decrypt the file:

The screenshot displays the CyberChef web application interface. On the left, the 'Operations' sidebar lists various file manipulation tasks. The main workspace shows a recipe titled 'AES Decrypt' with the following settings: Key set to 'f3fc056da1185eae370d76d47c4cf9db9f4efd1c1585cde3a7bcc6cb5889f6db01448c7909939e13ce359710b9f0dc2e' in HEX format, IV set to '01448c7909939e13ce359710b9f0dc2e' in HEX format, Mode set to 'CBC', and Input/Output set to 'Raw'. Below the recipe, the 'Detect File Type' section is active, showing checkboxes for Images, Video, Audio, Documents, Applications, Archives, and Miscellaneous, all of which are checked. The 'Output' section on the right shows the decrypted file details: Name: 'expanding-horizon.s.pdf.24bes', Size: '1,349,568 bytes', Type: 'unknown', and Loaded: '100%'. The 'Output' pane displays the decrypted content, which is a PDF file. The bottom status bar indicates the file size is 1349568 bytes and the processing time is 329ms.

Once both files have been decrypted we are able to get the last two answers for our investigation.



Introduction

Forela is expanding into the **Australian market** and needs a strategic business plan to ensure success. This presentation will outline the steps necessary to enter this new market and achieve our goals.



Forela Group

100 High Street
London,
SW1A 1AA
United Kingdom

Dear Board of Directors:

I am writing to inform you that Forela Group is interested in acquiring Notionwide Bank. Our company is a well-established financial institution with a strong track record of success, and we believe that the acquisition of Notionwide Bank would be a strategic move for us.

We believe that our offer would be beneficial for both companies, our customers, and stakeholders. By combining our resources, we can create a stronger and more competitive bank that will provide superior service and better financial products to our customers.

We are prepared to offer a generous price for Notionwide Bank, and we are confident that this offer will be compelling to your board of directors and shareholders. We are also prepared to work with your management team and employees to ensure a smooth transition and a successful integration of our two companies.

We understand that this proposal may come as a surprise, and we are prepared to answer any questions you may have about our company, our offer, and our plans for the future. We have engaged the services of reputable financial and legal advisors to assist us in this process, and we are confident that we can negotiate a mutually beneficial agreement.

We believe that this acquisition is in the best interest of both companies, and we hope that you will consider our proposal. We look forward to the opportunity to discuss this matter with you further.

Sincerely,

Happy Grunwald
CEO, Forela Group



Questions

1. What type of encryption has been utilised to encrypt the files provided?
2. Which market is our CEO planning on expanding into? (Please answer with the wording utilised in the PDF)
3. Please confirm the name of the bank our CEO would like to takeover?
4. What is the file name of the key utilised by the attacker?

updater

5. What is the file hash of the key utilised by the attacker?

950efb05238d9893366a816e6609500f

6. What is the BTC wallet address the TA is asking for payment to?

1BvBMSEYstWetqTFn5Au4m4GFg7xJaNVN2

7. How much is the TA asking for?

£1000000

8. What was used to pack the malware?

upx